

UNIVERSIDADE DE MOGI DAS CRUZES
BACHARELADO EM ENGENHARIA DE SOFTWARE

FABRÍCIO ROCHA DE SOUZA
GUILHERME AIRES PIMENTA DE MACEDO
LUIZ EDUARDO DIAS
MARIANA DA ROCHA PEREIRA MOREIRA

SISTEMA DE VALIDAÇÃO DE IMAGENS E AUTENTICAÇÃO SEGURA

Mogi das Cruzes, SP

2026

UNIVERSIDADE DE MOGI DAS CRUZES
BACHARELADO EM ENGENHARIA DE SOFTWARE

FABRÍCIO ROCHA DE SOUZA
GUILHERME AIRES PIMENTA DE MACEDO
LUIZ EDUARDO DIAS
MARIANA DA ROCHA PEREIRA MOREIRA

SISTEMA DE VALIDAÇÃO DE IMAGENS E AUTENTICAÇÃO SEGURA

Projeto de conclusão de disciplina apresentado
ao curso de Engenharia de software da
Universidade de Mogi das Cruzes.

Prof. Orientador: Fabiano Bezerra Menegidio

Mogi das Cruzes, SP

2026

RESUMO

Este trabalho apresenta o desenvolvimento de um sistema web voltado à análise de imagens com o objetivo de identificar conteúdos potencialmente gerados por inteligência artificial, aliado a um robusto mecanismo de autenticação e segurança da informação. O sistema implementa autenticação em dois fatores (2FA), controle de acesso, auditoria, controle de acesso criptografado e foco na segurança.

Palavras-chave: segurança; autenticação; 2FA; LGPD.

ABSTRACT

This work presents the development of a web system focused on image analysis, aiming to identify content potentially generated by artificial intelligence, combined with a robust authentication and information security mechanism. The system implements two-factor authentication (2FA), access control, auditing, encrypted access control, and a strong focus on security.

Keywords: security; authentication; 2FA; LGPD.

LISTA DE ILUSTRAÇÕES

SUMÁRIO

INTRODUÇÃO	7
1. VISÃO GERAL DO SISTEMA	8
1.1 Requisitos Funcionais de Segurança (RF-SEG)	8
1.2 Requisitos Não-Funcionais de Segurança e Privacidade (RNF-SEG)	9
1.3 Diagrama de Arquitetura	10
1.4 Fluxos de autenticação e dados documentados	10
1.5 Gestão de credenciais	14
1.6 Criptografia	15
1.7 Ativos do sistema	15

INTRODUÇÃO

O avanço acelerado da inteligência artificial tem possibilitado a criação de conteúdos digitais cada vez sofisticados. Modelos baseados em técnicas como Generative Adversarial Networks (GANs) e outras abordagens têm sido amplamente utilizadas para produzir imagens com o mais alto grau de realismo, tornando cada vez mais difícil para as pessoas distinguirem conteúdos autênticos daqueles gerados artificialmente.

Nesse contexto, surgem grandes preocupações relacionadas à confiabilidade da informação, à disseminação de desinformação e ao uso indevido dessas tecnologias, tornando-se essencial o desenvolvimento de ferramentas capazes de auxiliar na identificação de conteúdos gerados por inteligência artificial. Paralelamente, o tratamento de dados exige extrema atenção às práticas de segurança da informação, especialmente no que diz respeito à proteção de dados pessoais, conforme estabelecido pela Lei Geral de Proteção de Dados Pessoais (LGPD).

Dessa forma, este trabalho tem como objetivo o desenvolvimento de uma aplicação web voltada à validação de imagens, capaz de indicar a probabilidade de um determinado conteúdo ter sido gerado por inteligência artificial, aliada à implementação de um conjunto de práticas e mecanismos de segurança da informação. O sistema proposto busca não apenas oferecer uma solução funcional, mas também atender a requisitos fundamentais de confidencialidade, integridade e disponibilidade dos dados.

1. Visão Geral do Sistema

O sistema proposto consiste em uma aplicação web voltada para a análise de imagens com o objetivo de identificar a probabilidade de terem sido geradas por inteligência artificial. A plataforma permite que os usuários autenticados realizem upload de imagens, as quais são processadas por um modelo de análise, retornando um índice probabilístico de geração por IA.

Além de sua funcionalidade principal, o sistema incorpora mecanismos de segurança da informação, incluindo autenticação de usuários, controle de acesso, recuperação de senha e proteção de dados sensíveis. A arquitetura foi projetada considerando os princípios da confidencialidade, integridade e disponibilidade (CIA), garantindo a proteção dos dados dos usuários e a confiabilidade do sistema.

O público-alvo inclui estudantes, pesquisadores e profissionais interessados em validar o conteúdo que circula por meio digital, seu acesso será via navegador web.

1.1 Requisitos Funcionais de Segurança (RF-SEG)

RF-SEG-01 (Controle de Acesso Baseado em Funções – RBAC): O sistema deve implementar controle de acesso segregado, garantindo que “Usuários Comuns” não tenham acesso às interfaces e rotas exclusivas de “Verificadores” ou “Administradores”.

RF-SEG-02 (Escaneamento de Malware em Uploads): O sistema deve verificar imagens enviadas para análise em busca de malwares antes de armazená-los no servidor.

RF-SEG-03 (Trilha de Custódia de Mídia): O sistema deve registrar um log imutável de todas as interações com uma mídia sob investigação. Deve ficar registrado quem baixou o arquivo, quem alterou o status de "em análise" para "fake news" e quando isso ocorreu, garantindo a integridade do laudo.

RF-SEG-04 (Gestão Avançada de Sessão): O sistema deve fornecer uma interface onde o usuário possa visualizar todos os dispositivos atualmente conectados à sua conta e permitir o “logout remoto” de sessões específicas.

RF-SEG-05 (Mascaramento de Dados – Data Masking): O sistema deve ofuscar informações sensíveis dos usuários (como e-mail parcial e telefone) nas telas de listagem administrativa, exibindo os dados completos apenas sob demanda e com registro de auditoria.

RF-SEG-06 (Anonimização de Relatórios): O sistema deve garantir que os laudos e estatísticas públicas geradas sobre desinformação sejam totalmente anonimizados, impedindo a reidentificação dos usuários que enviaram as mídias originais.

1.2 Requisitos Não-Funcionais de Segurança e Privacidade (RNF-SEG)

RNF-SEG-01 (Política de Retenção e Descarte Automático): O sistema deve implementar uma rotina automatizada que exclua de forma irrecuperável (data wiping) arquivos de mídia e dados pessoais de contas inativas após 5 anos, em alinhamento aos princípios da LGPD.

RNF-SEG-02 (Defesa contra XSS e Injeções): A aplicação web deve implementar cabeçalhos de segurança estritos, incluindo Content Security Policy (CSP), para mitigar ataques de Cross-Site Scripting (XSS) e injeção de código.

RNF-SEG-03 (Vinculação de Sessão - Session Binding): Para evitar que um invasor roube o cookie de sessão de um usuário e acesse a conta de outro computador (ataque de Session Hijacking), o sistema deve invalidar a sessão imediatamente se detectar uma mudança drástica no endereço IP ou no navegador (User-Agent).

RNF-SEG-04 (Segregação de Privilégios no Banco de Dados): A aplicação deve conectar-se ao banco de dados utilizando um usuário com privilégios restritos (apenas DML – Data Manipulation Language), sem permissões para alterar a estrutura do banco (DDL).

RNF-SEG-05 (Rate Limiting de Serviços de Negócio): Além das rotas de autenticação, as APIs de envio de mídia para análise devem possuir limitação de requisições por minuto por IP (Rate Limit), prevenindo ataques de Negação de Serviço (DoS) e esgotamento de recursos.

RNF-SEG-06 (Proteção de Formulários Abertos): Todas as rotas públicas de submissão de links ou mídias devem implementar desafios anti-bot (como um CAPTCHA invisível) para evitar ataques de automação, spam ou exaustão de recursos.

1.3 Diagrama de Arquitetura

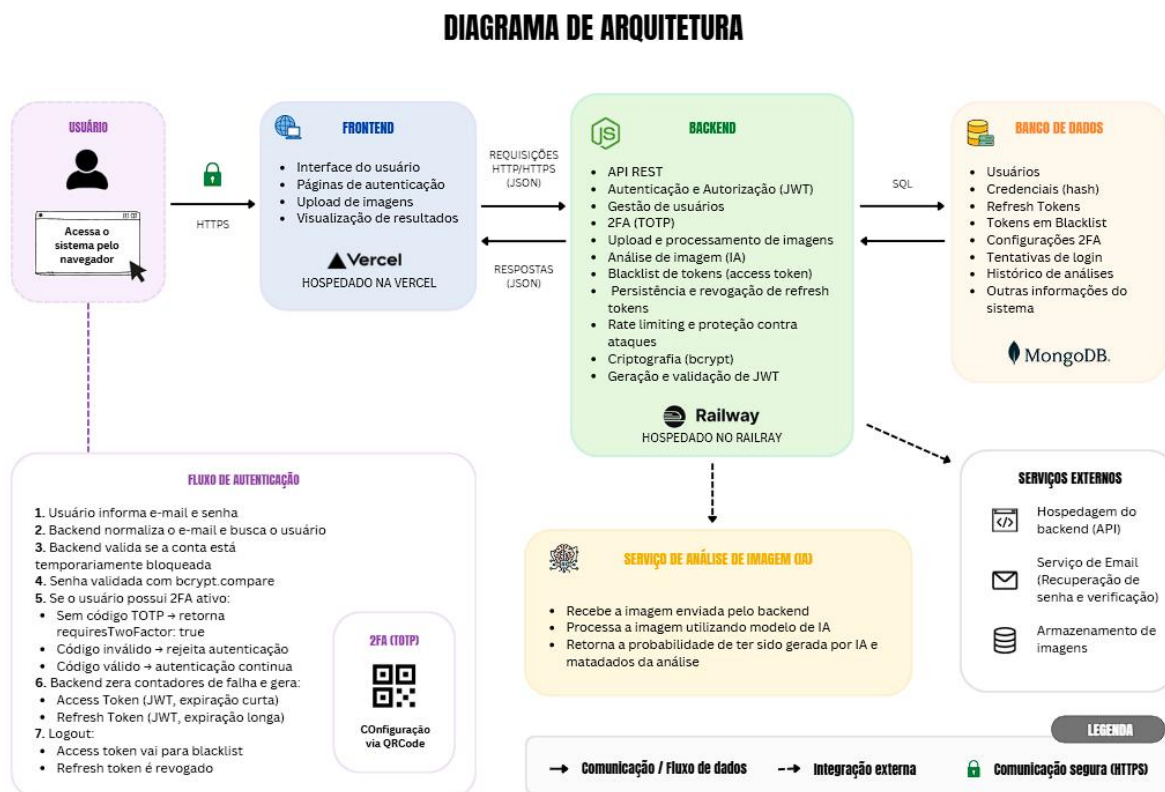


Figura 1: Apresenta o diagrama de arquitetura do projeto.

1.4 Fluxos de autenticação e dados documentados

O fluxo de autenticação do sistema foi projetado com foco em segurança, controle de acesso e mitigação de ataques automatizados, seguindo os itens abaixo:

1. Inicialmente, o usuário fornece suas credenciais (e-mail e senha), as quais são processadas pelo backend.
2. O e-mail informado é normalizado para evitar inconsistências e, em seguida, o sistema realiza a busca do usuário na base de dados. Antes da validação da senha, é verificado se a conta encontra-se temporariamente bloqueada em decorrência de múltiplas tentativas de autenticação mal sucedidas, mecanismo adotado para mitigar ataques de força bruta. E a validação da senha é realizada utilizando ‘`bcrypt.compare`’, garantindo proteção contra ataques de exposição de credenciais.

3. Caso o usuário possua autenticação em dois fatores (2FA) habilitada, o fluxo incorpora uma etapa adicional baseada em código TOTP (Time-Based One-Time Password). Nessa etapa, ocorre as seguintes ações:
 - Sem código: o backend retorna 'requiresTwoFactor: true';
 - Código inválido: o backend rejeita a autenticação;
 - Código válido: a autenticação prossegue.
4. Após a autenticação bem-sucedida, o sistema realiza a limpeza dos contadores de falhas e gera dois tokens distintos baseados em JSON Web Token (JWT):
 - Um access token de curta duração, utilizado para autenticação nas requisições;
 - Um refresh token de longa duração, utilizado para controle de sessões e revogação posterior.
5. O refresh token é persistido no banco de dados, permitindo controle de sessões e revogação posterior.
6. No processo de logout, o sistema invalida o access token por meio de blacklist e revoga o refresh token, garantindo que a sessão não possa ser reutilizada.

No que se refere ao fluxo de dados, o sistema segue uma arquitetura segura na qual todas as requisições autenticadas dependem da validação do token JWT. O envio de imagens para análise ocorre apenas após autenticação válida, sendo o processamento realizado pelo backend e o resultado retornado ao usuário de forma segura.

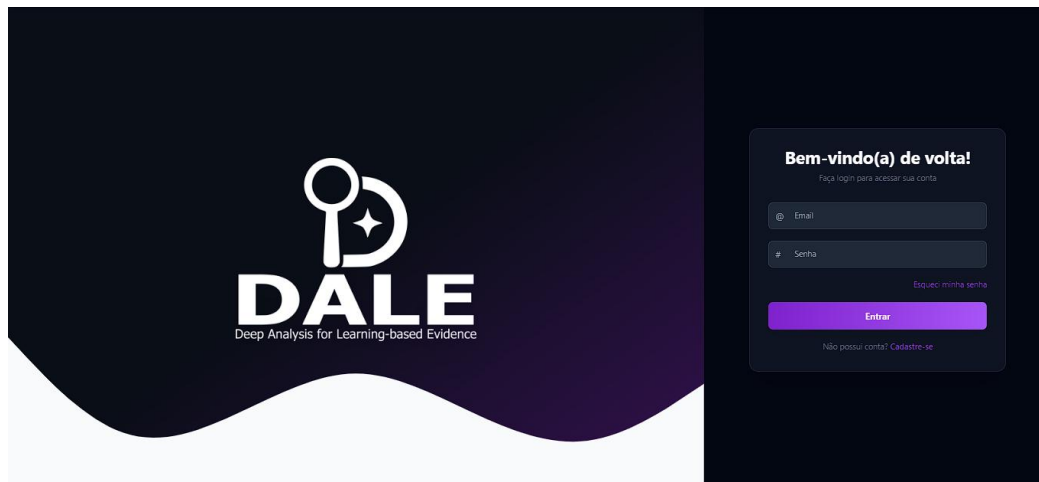


Figura 2: Apresenta tela de login.

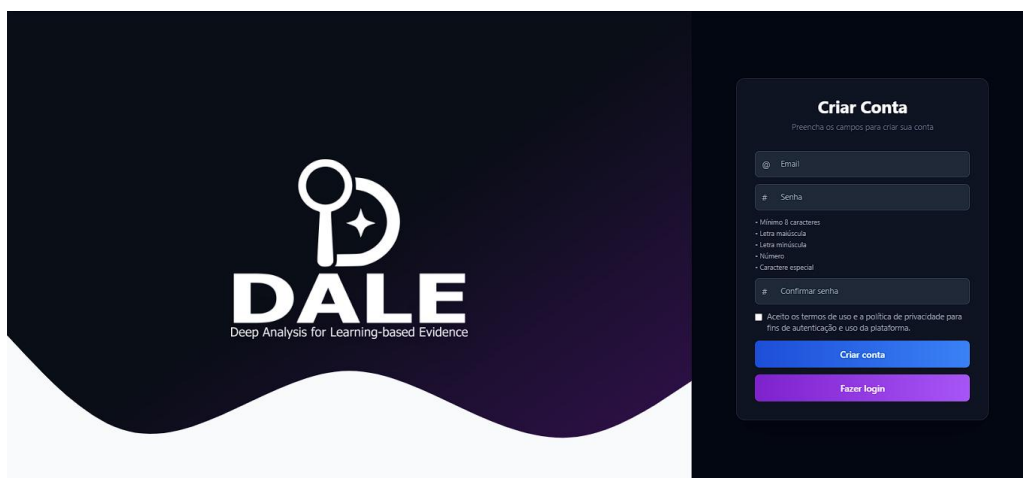


Figura 3: Apresenta tela de cadastro com senha válida.

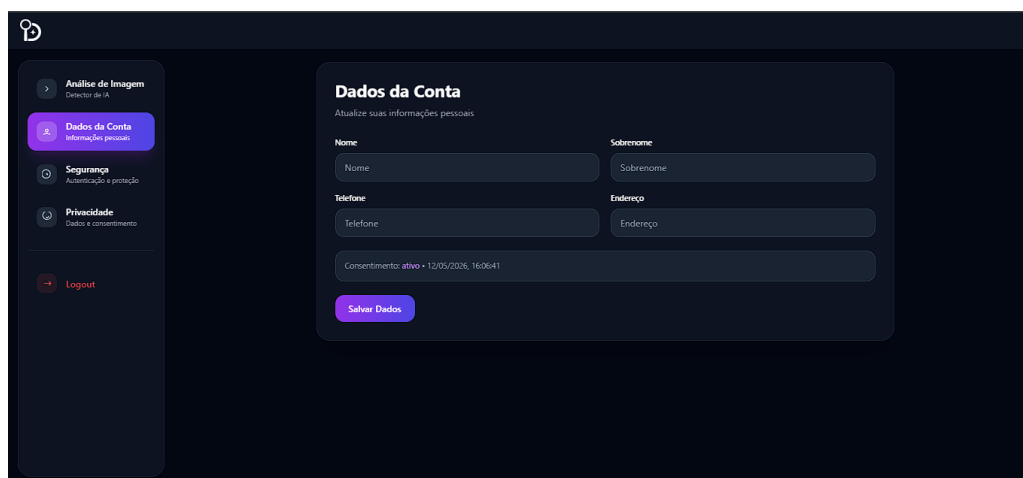


Figura 4: Apresenta tela após logar com sucesso.

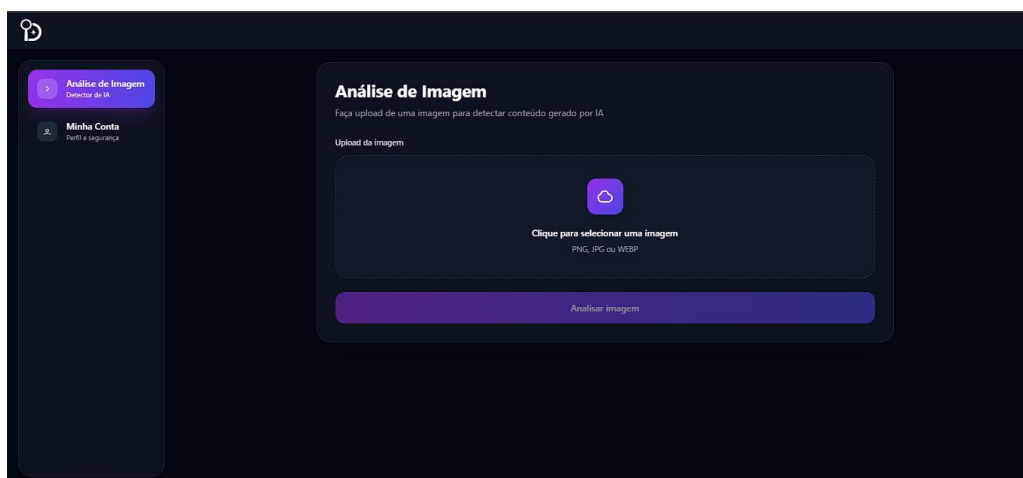


Figura 5: Apresenta tela para análise de imagens.

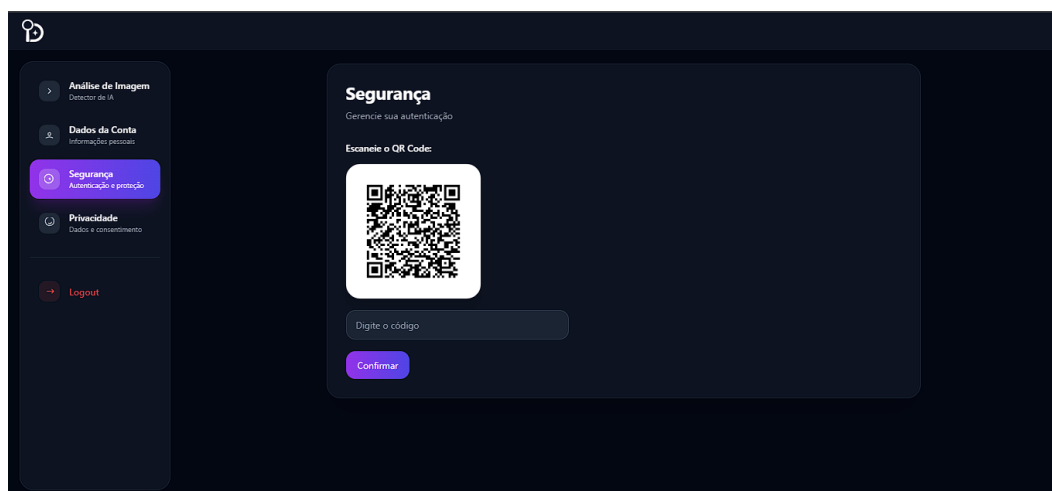


Figura 6: Apresenta tela com QR Code de ativação do 2FA.

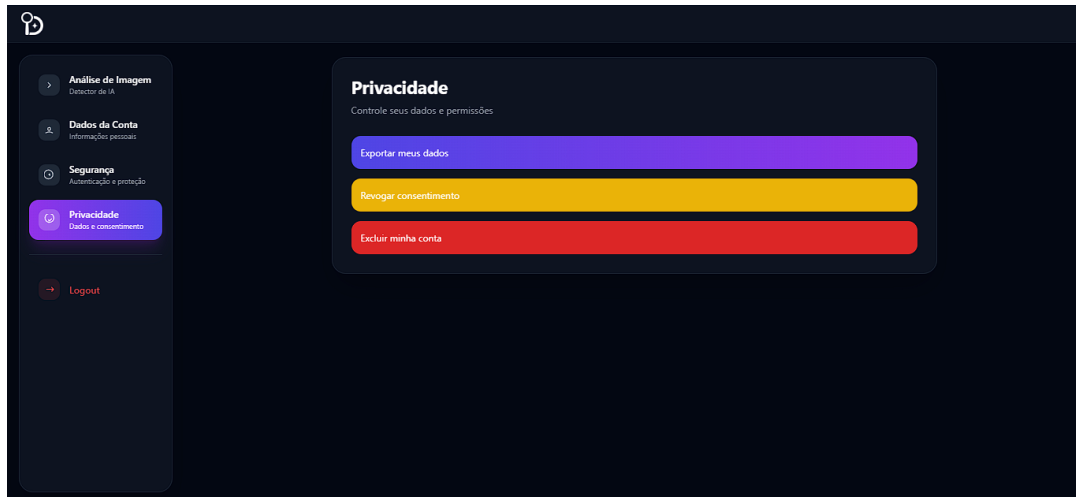


Figura 7: Apresenta tela para controle dos dados.

1.5 Gestão de credenciais

As senhas dos usuários são armazenadas utilizando o algoritmo bcrypt com 12 rounds. Essa escolha garante resistência a ataques de força bruta, ao mesmo tempo em que mantém desempenho adequado para o sistema. O uso de hash com salt embutido torna inviável a recuperação das senhas originais, mesmo em cenários de vazamento de dados.

Para o gerenciamento de sessões, o sistema adota uma arquitetura baseada em JSON Web Token (JWT), utilizando uma estratégia de dupla camada composta por access tokens de curta duração e refresh tokens de longa duração. Essa abordagem reduz o comprometimento do token e permite uma renovação controlada.

A persistência dos refresh tokens em banco de dados permite o controle das sessões, possibilitando sua revogação em eventos como logout ou detecção de comportamento suspeito. Complementarmente, o uso de blacklist para access tokens impede a reutilização de tokens após o encerramento da sessão, reforçando o controle de acesso.

O sistema incorpora autenticação em dois fatores (2FA) baseada em Time-based One-Time Password (TOTP), configurada via QR Code. Essa medida adiciona uma camada adicional de segurança, protegendo contas mesmo em casos de comprometimento de credenciais primárias.

Adicionalmente, foram implementados mecanismos de proteção contra-ataques automatizados e tentativas de exploração de credenciais, incluindo:

- Limitação de taxa de requisições (*rate limiting*);

- Bloqueio temporário de contas após múltiplas tentativas inválidas;
- Introdução de atrasos progressivos entre tentativas de autenticação.

1.6 Criptografia

O sistema utiliza criptografia em múltiplas camadas para garantir a tríade da segurança (Confidencialidade, Integridade e Disponibilidade):

- **Hash de Senhas:** No serviço de autenticação (authService.js), as senhas são criptografadas utilizando o algoritmo bcrypt com um fator de custo (salt) de 12 rounds, garantindo que mesmo em caso de vazamento da base MongoDB as senhas originais permaneçam protegidas contra-ataques de dicionário.
- **Tokens de Sessão (JWT):** A autenticação é provida por JSON Web Tokens. O tokenService.js gera dois tipos de tokens: um accessToken de curta duração para autorização de rotas e um refreshToken de longa duração para manutenção da sessão. Ambos são assinados digitalmente para evitar manipulação de carga útil.
- **Segurança em Trânsito:** A comunicação entre o frontend (Vercel) e o backend (Railway) é protegida por HTTPS/TLS, assegurando que os dados e imagens trafeguem de forma cifrada pela rede.
- **Autenticação de Dois Fatores (2FA):** Utiliza-se o protocolo TOTP (Time-based One-time Password) através da biblioteca Speakeasy, gerando segredos criptográficos únicos vinculados ao perfil do usuário e visualizados via QR Code.

1.7 Ativos do Sistema

Os ativos foram classificados de acordo com sua importância para a operação do sistema:

- **Ativos de Dados:** Banco de dados MongoDB, contendo credenciais (hashes), tokens em blacklist e as configurações de 2FA.
- **Ativos de Software:** Código-fonte do backend em Node.js e interface React frontend.

- **Ativos de Infraestrutura:** Instâncias de hospedagem na Vercel e Railway.
- **Ativos de Identidade:** Segredos de 2FA e chaves privadas de assinatura de tokens JWT.

CONCLUSÃO

A aplicação desenvolvida alcançou os objetivos propostos ao oferecer um ambiente seguro para análise de imagens potencialmente geradas por inteligência artificial, aliado a práticas de autenticação forte, controle de sessões e proteção contra ameaças comuns em aplicações web. Recursos como autenticação em dois fatores (2FA), utilização de JWT, criptografia com bcrypt, rate limiting e controle de acessos contribuíram significativamente para o fortalecimento da segurança do sistema.

Além disso, o projeto buscou atender princípios relacionados à privacidade e conformidade com a Lei Geral de Proteção de Dados (LGPD), incorporando funcionalidades como consentimento do usuário, exportação de dados pessoais, revogação de consentimento e exclusão de conta. Essas práticas reforçam a importância da responsabilidade no tratamento de dados e evidenciam a preocupação com a transparência e a segurança das informações armazenadas.

Do ponto de vista acadêmico e técnico, o desenvolvimento da aplicação proporcionou experiências práticas relacionadas à arquitetura em camadas, integração entre frontend e backend, implementação de APIs REST, autenticação segura e organização de sistemas escaláveis. O projeto também possibilitou maior compreensão sobre os desafios atuais envolvendo conteúdos gerados por inteligência artificial e os impactos da segurança da informação no contexto digital.

Por fim, conclui-se que o sistema desenvolvido apresenta uma solução funcional, moderna e alinhada às boas práticas de desenvolvimento seguro, demonstrando o potencial de aplicações que unem inteligência artificial, autenticação forte e proteção de dados para promover maior confiabilidade e segurança no ambiente digital.

REFERÊNCIAS

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Diário Oficial da União: seção 1, Brasília, DF, 15 ago. 2018. Disponível em: <https://www.planalto.gov.br>. Acesso em: 23 abr. 2026.

ISO/IEC 27001. Information technology — Security techniques — Information security management systems — Requirements. Geneva: ISO, 2013.

REPOSITÓRIOS

Backend: <https://github.com/guilhermemacedo20/image-validator-backend>

Frontend: <https://github.com/guilhermemacedo20/image-validator-frontend>

Site: <https://image-validator-frontend-cyan.vercel.app>